

PLANTILLA REPORTE EJECUTIVO EN POWERPOINT

Presentación Madurez Ciberseguridad 7 Módulos

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: Encuesta Integral Ciberseguridad Organizacional

Duración: 30-45 minutos (18-22 diapositivas)

Software: Microsoft PowerPoint / Google Slides

INTRODUCCIÓN: ESTRUCTURA PRESENTACIÓN

Story arc ejecutivo (engagement + decisión):

1. **Hook:** Riesgo regulatorio (NIS2, 6 meses)
2. **Context:** Dónde estamos (IMC 39, Nivel 2)
3. **Analysis:** Qué está bien vs qué falta
4. **Solution:** 18-month roadmap
5. **Action:** Decisiones ejecutivas requeridas

DIAPOSITIVA 1: PORTADA

CYBERSECURITY MATURITY ASSESSMENT 2026
Evaluación Integral: 7 Módulos, 51 Preguntas

Framework: GQM Methodology + NIS2 Compliance
Alineación: España / EU Regulaciones

Organization: [COMPANY NAME]
Assessment Date: Enero 2026
Presented By: CISO / Chief Information Officer

Classification: Confidencial - Gerencia

****Design:****

- Logo empresa top-right
- Colores corporativos
- Fecha/contexto prominente
- Classification marking

DIAPOSITIVA 2: AGENDA

AGENDA - 45 MINUTOS		
1. Contexto & Propósito	[3 min]	
• Por qué este assessment • NIS2 deadline (Agosto 2026) • Alineación regulatoria		
2. Resumen Ejecutivo	[5 min]	
• IMC Global (39/100) • Comparación vs benchmark • Posicionamiento actual		
3. Análisis Detallado 7 Módulos	[15 min]	
• Scorecard por módulo • Top 3 fortalezas • Top 3 críticos gaps		
4. Compliance Normativo	[5 min]	
• NIS2 readiness: 72% • ISO 27001 readiness: 68% • Gaps identificados		
5. Roadmap & Inversión	[10 min]	
• 4 fases de implementación • €2.1M investment Year 1 • ROI projections		
6. Decisiones & Next Steps	[5 min]	
• 5 decisiones ejecutivas • Timeline comprometimiento • Responsabilidades		
Q&A / Discusión	[2 min]	

DIAPOSITIVA 3: CONTEXTO Y MOTIVACIÓN

¿POR QUÉ ESTE ASSESSMENT?
● REGULATORY DRIVERS (Crítico 2026) - NIS2 Transposición: Agosto 31, 2026 €50M penalty o 10% turnover si no cumple - Entidad "esencial" según criterios España - Requires 95%+ compliance en 11 puntos clave - Assessment independiente auditado - ISO 27001 Certification Goal - Cliente/regulatory requirement - Current gap: 68% vs 95% required - Audit timeline: Q4 2026 ● STRATEGIC DRIVERS - Incident Prevention - Industry breach cost: €500K-€2M per evento - Our MTTD: 50 días (target <24h) - Prevention ROI: 3-4x investment - Competitive Positioning - Peers at 70-80% maturity - Client confidence critical (B2B) - Accelerate adoption ● OPERATIONAL DRIVERS - Team Capability Gap - Growing cyber threat landscape - Resource constraints - Need prioritization framework ✓ This assessment provides diagnostic roadmap

Visualization:

- 3-4 boxes stacked (red/yellow/green)
- Timeline urgency callout (6 months to NIS2)
- Impact metrics

DIAPOSITIVA 4: RESUMEN EJECUTIVO - IMC GLOBAL

MATURITY SNAPSHOT: Current State Q1 2026

IMC SCORE: 39/100

Level 2 - REPETIBLE (Emerging Processes)

- ✓ Some processes documented
- ✓ Partial execution consistency
- x Limited integration across functions
- x Minimal automation / AI enhancement

vs INDUSTRY LANDSCAPE:

- Your Org: 39 (Level 2)
- Industry Avg: 38 (Level 2)
- Top Quartile: 72+ (Level 3-4)

↑ +1pp vs avg but -33pp vs leaders ⚠

REGULATORY COMPLIANCE:

NIS2 Readiness: 72% (Target: 95%)
ISO 27001 Readiness: 68% (Target: 95%)
GDPR Alignment: 75% (Target: 100%)

Compliance Average: 72% → 23pp gap to goal

⚠ CRITICAL: 11 meses para NIS2 deadline
6+ months acción acelerada requerida

****Visualizations:****

- Large gauge/dial showing 39/100 (green at 39, red at 95)
- Bar chart: Your org vs industry vs leaders
- Compliance radar (3-point: NIS2, ISO, GDPR)
- Urgency callout (red) for deadline

DIAPOSITIVA 5: SCORECARD 7 MÓDULOS

DETAILED ASSESSMENT: 7 MÓDULOS SCORECARD					
Módulo	Score	Level	Compliance	Status	
1. Gobernanza	44	2-3	80%	🟡	Amber
2. Vulnerabilidades	42	2	65%	🔴	Red
3. SIEM	35	2	60%	🔴	Red
4. Acceso/Identidad	48	2	70%	🟡	Amber
5. Capacitación	52	3	80%	🟢	Green
6. Incidentes	40	2	68%	🟡	Amber
7. Estrategia	32	1-2	55%	🔴	Red
PORTFOLIO AVG		39	2	68%	LEVEL 2
INTERPRETATION:					
🟢 GREEN (Score 50+): Ready for optimization Módulo 5 (Capacitación) - continue momentum					
🟡 AMBER (Score 40-50): Emerging but incomplete Módulos 1,4,6 - require investment Plan: Phase 2 improvements Q2-Q3 2026					
🔴 RED (Score <40): Critical gaps Módulos 2,3,7 - highest priority intervention Plan: Immediate remediation starting Q2 2026					
OVERALL: Mixed maturity picture					
Strengths exist but gaps prevent					
Level 3 (Defined) achievement					

****Visualization:****

- Horizontal bar chart (7 bars, color-coded)
- Traffic light indicators
- Heat map intensity

DIAPPOSITIVA 6: TOP 3 FORTALEZAS

TOP 3 ORGANIZATIONAL STRENGTHS

- 1** SECURITY AWARENESS PROGRAM (Module 5: 52/100)
- ✓ Phishing click-rate 28% → improving trend
 - ✓ Annual training >85% completion
 - ✓ Board-level awareness increasing
 - Advantage: Cultural foundation for change
 - Impact: Incident reduction 15-20% likely

Recomendación: Capitalizar momentum

- └ Expand training 2026; add gamification
- Timeline: Q2-Q4 2026; Owner: CHRO/CISO

- 2** GOVERNANCE STRUCTURE POSITIONING (Module 1: 44)
- ✓ CISO reports to COO (near-C-level)
 - ✓ Cybersecurity budget line item
 - ✓ Board-level cybersecurity discussions begun
 - Advantage: Strategic alignment & authority
 - Impact: Faster decision-making; priority

Recomendación: Formalize CISO reporting to CEO

- └ Q1 2026 decision; elevate to C-suite
- Timeline: Q1 2026; Owner: CEO/CISO

- 3** ACCESS CONTROL MATURITY (Module 4: 48)
- ✓ Centralized identity system (AD) deployed
 - ✓ MFA on VPN/critical systems (60% coverage)
 - ✓ Starting PAM program discussion
 - Advantage: Foundation for zero-trust move
 - Impact: Unauthorized access reduction 40-50%

Recomendación: Expand MFA; deploy PAM

- └ Full MFA rollout by Q4 2026
- Timeline: Q2-Q4 2026; Owner: IT Security

STRATEGIC IMPLICATION:

Strong governance + awareness foundation

- enables rapid improvements in technical domains
- Focus next investment on VM, SIEM, Strategy

Visualization:

- 3 large boxes/cards (green)
- Up-trend arrows
- Icons per strength
- Connected to roadmap

DIAPOSITIVA 7: TOP 3 CRITICAL GAPS

TOP 3 CRITICAL GAPS (Action Priority)

- **GAP #1: STRATEGY & ROADMAP (Module 7: 32/100)**
Current State:
 - No integrated cybersecurity strategy
 - Projects ad-hoc; no prioritization
 - Unclear link: initiatives → business goals
 - Resource conflicts across teams

Business Impact:

- Wasted investment; duplication
- Slow decision-making; no clarity
- Estimated waste: €200K-€300K/year

Remediation Plan:

1. Develop comprehensive cybersecurity strategy aligned with business (Q1-Q2 2026)
2. Create 3-year roadmap (phases 1-4)
3. Establish steering committee governance
4. Quarterly strategy reviews with board

Investment: €60K (consultant) + internal
Expected ROI: 30% reduction in waste

- **GAP #2: SIEM & DETECTION (Module 3: 35/100)**
Current State:
 - No enterprise SIEM deployed
 - Point tools (IDS, logs) not integrated
 - Manual log analysis; low coverage
 - MTTD: 50 days (vs <24h target)
 - SOC not 24/7; limited threat hunting

Business Impact:

- Breach detection delays → escalation costs
- Estimated incident impact: €500K-€2M each
- Probability: 1-2 incidents annually
- Regulatory gap (NIS2 Art.17)

Remediation Plan:

1. SIEM procurement & deployment (Q2 2026)
2. Integrate 8+ log sources by Q3 2026
3. Hire/train SOC analyst (0.5-1 FTE)
4. Implement detection rules (top 30 MITER ATT&CK)
5. Establish threat hunting program (Q4 2026)

Investment: €350K Year 1
Expected ROI: €500K+ (incident prevention)
Timeline to Compliance: Q4 2026 (NIS2)

- **GAP #3: VULNERABILITY MANAGEMENT (Module 2: 42)**
Current State:
 - Scanning quarterly (not continuous)
 - MTTR critical vulns: 22 days (target <15)
 - No automated patch management
 - SBOM missing for 60% critical apps
 - SLA compliance: 72% (target 90%+)

Business Impact:

- Average 20-day exposure window per vuln
- 50% of breaches exploit known vulns
- PCI-DSS failure risk (if applicable)
- Estimated risk cost: €1.5-€3M/year

Remediation Plan:

1. Deploy continuous vulnerability scanning
2. Implement automated patching (Q2 2026)
3. Establish SBOM requirements (Q2 2026)
4. Target MTTR <5 days by Q4 2026
5. Risk-based prioritization (threat intel)

Investment: €280K Year 1

Expected ROI: €600K+ (downtime reduction)

Timeline to Compliance: Q4 2026 (NIS2 Art.19)

OVERALL IMPACT OF 3 GAPS:

Combined risk: €2-€5M potential incidents

Combined investment to remediate: €690K

Expected ROI: 250-600% annually

Timeline to Level 3: 9-12 months with focus

****Visualization:****

- 3 red boxes stacked
- Each with: Current → Business Impact → Remediation
- Icons for criticality
- Timeline/investment callouts

DIAPOSITIVA 8: REGULATORY COMPLIANCE HEATMAP

REGULATORY ALIGNMENT ANALYSIS

	NIS2 Directive	ISO 27001 2022	GDPR 2016/679
	Transposition Aug 2026	Certification Target Q4 2026	Article 32 Ongoing
Assessment Coverage	72% ☐	68% ☐	75% ☐
Target 2026	95% ☒	95% ☒	100% ☒
Gap	-23% ☒	-27% ☒	-25% ☒
Deadline	11 months	10 months	Ongoing

PRIORITY MAPPING (NIS2 Article Numbers):

Art.19 - Cybersecurity measures

- └ Vulnerability Management: 65% (need +30%)
- └ Configuration Management: 70% (need +25%)
- └ Access Control: 70% (need +25%)
- └ Encryption: 75% (need +20%)

Art.17 - Governance & Leadership

- └ CIS0 role/responsibility: 80% (need +15%)
- └ Board reporting: 70% (need +25%)
- └ Risk assessment: 72% (need +23%)

Art.18 - Incident Reporting

- └ Incident detection: 60% (need +35%) ☒
- └ Reporting procedures: 75% (need +20%)
- └ Timeline: 72h notification: 80% (need +15%)

ACTION PLAN PRIORITIZATION:

Q2 2026 (Next 3 months):

- ✓ Incident detection capability (SIEM)
- ✓ Vulnerability management continuous
- ✓ Access control full MFA rollout

Q3 2026 (Months 4-6):

- ✓ Configuration management formalization
- ✓ Risk assessment methodology
- ✓ Encryption standards definition

Q4 2026 (Months 7-11):

- ✓ Final compliance validation
- ✓ Audit readiness demonstration
- ✓ NIS2 deadline (August 31) ✓✓✓

⚠ CRITICAL PATH: Month 6-11 are crunch time

Visualization:

- Heat map grid (NIS2 x detail areas)
- Red/Yellow/Green intensity coding

- Gantt timeline below
- Urgency indicators

DIAPOSITIVA 9: IMPLEMENTATION ROADMAP

ROADMAP: 4 PHASES / 18 MONTHS

Q1 2026 Q2 2026 Q3-Q4 2026 2027

Phase 1: Foundation (1 mo) - €0 internal

Focus: Governance formalization

- CISO reporting to CEO established
- Steering committee created
- Strategy document drafted
- Budget allocation Q2-Q4 approved

Success: IMC 39 → 45

Phase 2: Core Technical (3 mo) - €1.2M

Focus: SIEM, VM, Acceso, Respuesta

- SIEM platform deployed (Modules 3)
- Vulnerability scanning automated (Module 2)
- MFA full rollout; PAM pilot (Module 4)
- IR playbooks + SOAR integration (Module 6)

Success: IMC 45 → 65; NIS2 readiness 72% → 88%

Phase 3: Compliance & Integration (3 mo) - €200K

Focus: NIS2/ISO validation; Optimization

- Final compliance gap closure
- Pen test & external audit prep
- Threat hunting program launch (Module 3)
- Strategy integration (Module 7)

Success: IMC 65 → 78; NIS2 95%+ ready

Phase 4: Advanced & Continuous (9+ mo) - €500K

Focus: AI/ML enhancement, Culture, Optimization

- AI-based threat detection enhancement
- Advanced incident response automation
- Zero-trust architecture planning
- Continuous improvement framework

Success: IMC 78 → 85+; Level 4 (Managed)

KEY MILESTONES:

31-Mar-2026: Governance foundation ✓
30-Jun-2026: Phase 2 core complete; 65 IMC
31-Aug-2026: NIS2 compliance 95%+ ✓✓✓
31-Dec-2026: IMC 78; ISO audit-ready
30-Jun-2027: IMC 85+; Level 4 achieved

****Visualization:****

- Gantt chart style (Q-by-Q)
- Color phase coding
- Milestones marked
- IMC trajectory curve overlay

DIAPOSITIVA 10: BUDGET & ROI

INVESTMENT & FINANCIAL CASE

YEAR 1 INVESTMENT BREAKDOWN (2026): €2.1M

Phase 1 (Foundation):	€0 (internal)
Phase 2 (Core Technical):	€1.2M
Phase 3 (Compliance):	€200K
Phase 4 (Advanced):	€700K (partial)

TOTAL CAPEX:	€1.4M
TOTAL OPEX:	€0.7M

YEAR 1 TOTAL:	€2.1M
---------------	-------

ROI SCENARIO ANALYSIS:

- CONSERVATIVE Scenario:
 - 1 incident prevented
 - Cost avoided: €500K
 - Net Year 1: -€1.6M (breakeven Year 3)
 - 3-Year ROI: 15% (breakeven value)
- REALISTIC Scenario (Most Likely):
 - 2 incidents prevented + efficiency gains
 - Cost avoided: €2-€2.5M
 - Net Year 1: +€400K
 - Payback: 10 meses
 - 3-Year ROI: 180% (€3.8M total benefit)
- OPTIMISTIC Scenario:
 - 3 incidents prevented + MTTR reduction
 - Cost avoided: €3.5-€4M
 - Net Year 1: +€1.4-€1.9M
 - Payback: 6 months
 - 3-Year ROI: 280% (€6.2M total benefit)

RECOMMENDATION: Plan for Realistic scenario
(based on peer benchmarks + industry analysis)

Business Case: 10-month payback provides
strong financial justification + regulatory
compliance guarantee

Visualization:

- Pie chart: CapEx vs OpEx
- Bar chart: 3 scenarios side-by-side
- Waterfall chart: €2.1M invested → benefits
- Payback timeline highlighted

DIAPOSITIVA 11: RISK IF NO ACTION

RISK IMPLICATIONS: Status Quo vs Action

● IF WE DO NOTHING (Status Quo):

1. REGULATORY FAILURE (CRITICAL)
 - NIS2 deadline Aug 31, 2026 (11 months)
 - Penalty: €50M or 10% annual turnover
 - Operational restrictions possible
 - Reputational damage (market loss)
2. SECURITY INCIDENTS (HIGH)
 - Probability: 1-2 breaches in 12 months
 - Average cost per breach: €500K-€2M
 - MTTD 50 days delays detection
 - Business disruption: €2-€10M
3. OPERATIONAL INEFFICIENCY
 - No strategic roadmap = wasted investment
 - Estimated waste: €200-€300K/year
 - Slow incident response (4+ hours)
 - Manual processes (analyst burnout)
4. COMPETITIVE DISADVANTAGE
 - Peers at 70-80% maturity move ahead
 - Client trust erosion (cyber question)
 - Deal losses to more secure competitors
 - Talent retention challenge

● IF WE INVEST (€2.1M Year 1):

1. REGULATORY COMPLIANCE ✓✓✓
 - NIS2 95%+ compliant by Aug 2026
 - Zero penalty risk
 - ISO 27001 audit-ready
2. BREACH PREVENTION ✓
 - MTTD: 50 days → <24 hours
 - Incident cost reduction: -60%
 - Expected ROI: €2-€2.5M Year 1
3. OPERATIONAL EXCELLENCE ✓
 - Strategic roadmap clarity
 - Prioritized investments (no waste)
 - Automated response: 4hr → 30min MTTR
4. COMPETITIVE ADVANTAGE ✓
 - Level 3-4 maturity (top quartile)
 - Client confidence (marketing point)
 - Talent attraction & retention ↑

FINANCIAL SUMMARY:

Do Nothing: €50-100M risk; €2-5M incidents
Invest €2.1M: €0 penalty; €0.5-1M saved from IR
+€2-2.5M incident prevention

Net benefit of action: €2.5-3.5M positive ROI

****Visualization:****

- Two columns: RED (do nothing) vs GREEN (invest)
- Impact bars with €€€ notation
- Risk severity indicators

DIAPOSITIVA 12: BOARD DECISIONS REQUIRED

5 EXECUTIVE DECISIONS REQUIRED

✓ **DECISION 1: Strategic Priority**
"Approve cybersecurity as strategic priority
aligned with NIS2 and business growth"

Recommendation: ☒ APPROVE
Rationale: Regulatory mandate + financial case
Timeline: Decision this month (Jan 2026)
Implication: Budget commitment; exec sponsorship

✓ **DECISION 2: Financial Authorization**
"Approve €2.1M investment for 2026
(€1.4M CapEx + €0.7M OpEx)"

Recommendation: ☒ APPROVE
Business Case: 10-month payback; 180% 3-yr ROI
Timeline: Budget approval by Feb 2026
Funding Source: [Finance to confirm]

✓ **DECISION 3: Governance Restructuring**
"CISO reporting line: [Current] → CEO
Establish Cybersecurity Committee (Board level)"

Recommendation: ☒ APPROVE
Rationale: NIS2 requirement; best practice
Timeline: Effective Q1 2026
Impact: +35% strategic alignment

✓ **DECISION 4: Risk Appetite Statement**
"Formalize acceptable cybersecurity risk
thresholds (MTTD <24h, MTTR <5d, etc.)"

Recommendation: ☒ APPROVE
Timeline: Formalize by Feb 2026
Owners: CISO + CRO

✓ **DECISION 5: Timeline Commitment**
"Commit to NIS2 compliance 95%+ by Aug 2026
Final validation by regulatory deadline"

Recommendation: ☒ COMMIT
Accountability: CISO/CTO/CHRO (executive team)
Quarterly Review: Board cybersecurity committee

DECISION SCORECARD:

☐ Strategic Priority:	☐ APPROVE	☐ PENDING	☐ REJECT
☐ Budget (€2.1M):	☐ APPROVE	☐ PENDING	☐ REJECT
☐ Governance Restructure:	☐ APPROVE	☐ PENDING	☐ REJECT
☐ Risk Appetite:	☐ APPROVE	☐ PENDING	☐ REJECT
☐ NIS2 Commitment:	☐ APPROVE	☐ PENDING	☐ REJECT

Authorized by: _____ Date: _____
(Board Chair / CEO)

Next Review: 90 days (April 2026)

****Visualization:****

- 5 checkboxes per decision (APPROVE/PENDING/REJECT)
- Recommendation callouts (green checkmark)
- Signature block bottom

DIAPOSITIVA 13: NEXT STEPS & Q&A

NEXT STEPS: 30-60-90 DAY ROADMAP

- 17** FIRST 30 DAYS (Feb 2026):
1. Board approval & decision formalization
 2. CISO reporting structure established
 3. Budget allocation finalized (CFO)
 4. Steering committee chartered
 5. Phase 1 deliverables (strategy doc, etc)
 6. Vendor evaluation for SIEM procurement

- 17** DAYS 30-60 (Mar 2026):
1. Phase 1 complete (governance foundation)
 2. Phase 2 initiation (SIEM, VM, etc.)
 3. Implementation team ramped up
 4. Vendor contracts signed
 5. Internal communication plan executed
 6. Board update #1 (progress review)

- 17** DAYS 60-90 (Apr 2026):
1. Phase 2 progress: 25-30% complete
 2. First systems live (pilot SIEM, MFA)
 3. NIS2 compliance checkpoint 1
 4. Team training/certification starting
 5. Metrics dashboard live
 6. Stakeholder communication (quarterly)

🎯 SUCCESS METRICS (by end 2026):

- ✓ IMC Score: 39 → 78 (Level 3-4)
- ✓ MTTD: 50 days → <24 hours
- ✓ MTTR: 22 days → <5 days (critical)
- ✓ NIS2 compliance: 72% → 95%+
- ✓ ISO readiness: 68% → 95%+
- ✓ Incident click-rate: 28% → <8%
- ✓ SLA compliance: 72% → 90%+
- ✓ SIEM operational; 24/7 SOC; threat hunts
- ✓ MFA universal rollout complete
- ✓ Governance formalized (CISO→CEO)

📞 QUESTIONS?

Contact: CISO@organization.com
Follow-up: Steering committee (monthly)
Board Update: Quarterly

Thank you for your attention & commitment to
robust cybersecurity governance & operations.

****Visualization:****

- 3 timeline boxes (30/60/90)
- Checkmark list with milestones
- Success metrics dashboard
- Contact info + thank you slide

DESIGN GUIDELINES

Global Style:

- Color scheme: Corporate + Red/Yellow/Green status
- Typography: 32-36pt titles, 18-24pt body
- Layout: 16:9 widescreen
- Margins: 1-inch minimum
- Icons: Status indicators, arrows, metrics
- Animation: Minimal; no distraction

Charts/Visualizations:

- Use charts sparingly; max 3 per slide
- Data labels required
- Accessible colors (colorblind-friendly)
- Legend placement consistent

Speaker Notes:

- 2-3 minutes per slide (max 30 min total)
- Key talking points outlined
- Anticipated questions/answers
- Credibility statements ("based on industry data")

FIN DE PLANTILLA POWERPOINT